

Analyse de sécurité · PDF Equilibrist

[<- Index](#) · [Architecture](#) · [Build](#)

> Document destiné à l'évaluation par le PISO / équipe SSI.

> Version : 1.0 · Juin 2026

■ 1. Nature de l'application

PDF Equilibrist est une application desktop Windows d'édition de fichiers PDF.

Caractéristique	Valeur
Type	Application native Windows (exe)
Langage	Python 3.12, compilé via PyInstaller
Interface	PyQt6 (framework Qt · pas de navigateur)
Réseau	**Aucune connexion réseau en fonctionnem
Stockage distant	Aucun · traitement 100 % local
Télémetrie	Aucune
Authentification	Aucune (pas de compte, pas de serveur)
Droits requis	Utilisateur standard · **pas d'administr
Périmètre registre	`HKEY_CURRENT_USER` uniquement

■ 2. Flux de données

```
Fichier PDF local
    .
    .
PDF Equilibrist (processus isolé, espace utilisateur)
    .   lecture / modification en mémoire
    .
Fichier PDF local (sauvegarde sur disque via fichier temporaire local)
```

Aucune donnée ne quitte le poste de travail en utilisation normale.

Exception : téléchargement initial des modèles OCR

La fonctionnalité OCR (reconnaissance de texte sur PDF scannés) utilise PaddleOCR. Les modèles d'inférence (~50 Mo) sont téléchargés une seule fois depuis les serveurs officiels de PaddlePaddle (bj.bcebos.com) au premier lancement de la fonction OCR, puis mis en cache dans %USERPROFILE%\paddlex\.

- Connexion sortante HTTPS unique, vers un CDN Baidu
- Non déclenchée automatiquement · uniquement si l'utilisateur clique sur un bouton OCR
- Peut être pré-téléchargée en amont sur un poste connecté et distribuée via le dossier %USERPROFILE%\paddlex\ sans jamais accéder à Internet

3. Dépendances tierces et surface d'attaque

3.1 Bibliothèques principales

Bibliothèque	Rôle	Licence	Mainteneur
PyMuPDF (libmupdf)	Moteur PDF · lecture, rendu, écriture	AGPL-3	Artifex Software
PyQt6	Interface graphique	GPL-3 / Commercial	The Qt Company
PaddleOCR	OCR scannés	Apache-2.0	Baidu
PaddlePaddle	Moteur deep learning (OCR)	Apache-2.0	Baidu
Pillow	Traitement d'images	HPND (permissive)	Python Imaging Library
pdf2docx	Conversion PDF · Word	Apache-2.0	Communauté
pdfplumber	Extraction tableaux PDF	MIT	Communauté
openpyxl	Génération Excel	MIT	Communauté
python-pptx	Génération PowerPoint	MIT	Communauté

3.2 Vecteurs d'attaque identifiés

Le vecteur d'attaque principal d'un éditeur PDF est un fichier PDF malveillant exploitant une vulnérabilité du parseur lors de l'ouverture.

Parseur PDF · libmupdf / PyMuPDF

LibMuPDF est la bibliothèque la plus exposée car elle parse directement le contenu PDF, y compris les flux compressés, les polices et les images embarquées.

CVE connues sur libmupdf (exemples) :

CVE	Sévérité CVSS	Type	Version corrigée
CVE-2023-31810	7.5 (High)	Heap buffer overflow sur police	MuPDF 1.22
CVE-2022-30974	5.5 (Medium)	Null pointer dereference	MuPDF 1.20
CVE-2022-30975	5.5 (Medium)	Stack exhaustion (récursion)	MuPDF 1.20
CVE-2021-4216	5.5 (Medium)	Floating point exception	MuPDF 1.19

Contexte atténuant :

- L'application utilise PyMuPDF · 1.27, corrigeant toutes les CVE ci-dessus.
- LibMuPDF est l'un des parseurs PDF les plus audités (utilisé dans Evince, Okular, Ghostscript). Sa base de code est relue régulièrement par la communauté open source et l'équipe Artifex.
- L'exploitation nécessite qu'un utilisateur ouvre délibérément un PDF piégé · le vecteur est identique à Acrobat Reader, Foxit, ou tout autre lecteur PDF.

Pillow (traitement d'images)

Pillow a historiquement eu des CVE liées au traitement d'images malformées (buffer overflow lors du décodage TIFF/PNG). Ces vulnérabilités sont systématiquement corrigées dans les versions mineures.

CVE récentes notables :

CVE	Sévérité	Type	Corrigé dans
CVE-2023-50447	8.8 (High)	Exécution de code via image BMP	Pillow 10.2.0

CVE-2023-44271

7.5 (High)

DoS via image TIFF infinie

Pillow 10.0.1

L'application utilise Pillow · 10.4, couvrant ces correctifs.

PaddlePaddle (moteur OCR)

PaddlePaddle charge des modèles d'inférence depuis le disque. Le format de sérialisation (.pdmodel) est contrôlé par Baidu et non exposé au contenu PDF. Une attaque par modèle malveillant nécessiterait de compromettre le répertoire %USERPROFILE%\paddlex\ · ce qui suppose déjà un accès local à la machine.

■ 4. Facteurs de réduction du risque

4.1 Open source · revue communautaire continue

L'ensemble de la pile dépendante est open source et publiée sur GitHub.

- Le code source est consultable par n'importe quel développeur ou chercheur en sécurité.
- Les CVE sont signalées publiquement et corrigées dans des délais courts (généralement < 30 jours pour les High/Critical).
- Les projets majeurs (PyMuPDF, Pillow, Qt) bénéficient d'audits de sécurité réguliers financés par leurs mainteneurs ou des organismes tiers (OpenSSF, OSTIF, etc.).

4.2 Isolation · pas de services, pas de réseau

- L'application ne démarre aucun service réseau (pas de port ouvert, pas de serveur HTTP, pas de socket en écoute).
- Elle n'a pas accès au réseau sauf lors du téléchargement initial des modèles OCR.
- Elle ne lit pas les mails, le presse-papier, les mots de passe ou les certificats système.

4.3 Installation sans privilèges élevés

- L'installateur NSIS installe dans %LocalAppData%\Programs\PDF-Equilibrist sans élévation UAC.
- Les clés de registre créées sont dans HKCU · isolation stricte au profil de l'utilisateur courant.
- Aucune DLL système n'est modifiée, aucun service Windows enregistré.

4.4 Sauvegarde réseau sécurisée

La sauvegarde vers des partages réseau (UNC, lecteurs mappés, VPN/ZScaler) utilise un passage par fichier temporaire local suivi d'un `shutil.copy2()` · évitant les problèmes de gestion des erreurs réseau par les bibliothèques C sous-jacentes.

■ 5. Comparaison avec les alternatives

Critère

PDF Equilibrist

Adobe Acrobat Reader

Foxit PDF Editor

Réseau en fonctionnement	Aucun	Télémétrie, mise à jour	Télémétrie, cloud
Collecte de données	Aucune	Oui (usage, erreurs)	Oui
Droits installation	Utilisateur	Admin recommandé	Admin recommandé
Code source auditable	· (open source)	·	·
CVE libmupdf récentes	Corrigées · 1.27	Surface propriétaire	Surface propriétaire

■ 6. Recommandations pour la mise en œuvre

Obligatoire

- Maintenir l'application à jour : chaque release recompile les dépendances avec les dernières versions. Appliquer les mises à jour dans un délai raisonnable (· 30 jours) après publication.
- Restreindre l'usage à des PDF de confiance : comme tout éditeur PDF, ne pas ouvrir de PDF provenant de sources inconnues ou d'e-mails non sollicités.
- Pré-distribuer les modèles OCR si les postes n'ont pas accès à Internet : copier %USERPROFILE%\paddlex\ depuis un poste de référence.

Recommandé

- Intégrer l'exé dans la whitelist antivirus (les exes PyInstaller génèrent parfois des faux positifs en raison de leur structure de compression).
- Ajouter bj.bcebos.com à la whitelist proxy/ZScaler si l'OCR doit être activée sans pré-distribution des modèles.

Optionnel · renforcement

- Signer l'exé avec un certificat de signature de code EV : élimine les avertissements SmartScreen, prouve l'origine de l'exécutible.
- Mettre en place un contrôle de version centralisé (SCCM / Intune) pour piloter les mises à jour depuis la DSI.

■ 7. Synthèse pour le PISO

Point	Évaluation
Exposition réseau	· Nulle en fonctionnement normal
Fuite de données	· Aucune · traitement 100 % local
Droits système	· Utilisateur standard uniquement
Surface CVE	· Inhérente à tout lecteur PDF · gérée
Traçabilité code	· 100 % open source, auditable
Comparaison secteur	· Profil de risque inférieur ou équivalent
Condition principale	· Maintenir les mises à jour applicative

Le risque résiduel est comparable à celui de tout lecteur PDF du marché, avec une surface d'exposition réseau inférieure aux solutions commerciales. Le caractère open source de la pile technique permet une vérification indépendante du code et une correction rapide des vulnérabilités identifiées.